

Phishing Email Detection & Awareness System

Prepared By : Muhammed Hadhi K P

Date : 05/03/2026

Project No. 002

Table of Contents

1. Title Page	1
2. Introduction.....	3
3. Tools Used	3
3.1 Google Admin Toolbox (Messageheader)	
3.2 MXToolbox (Email Header Inspection)	
3.3 WHOIS Domain Analysis Tools	
4. Phishing Email Sample Analysis	5
4.1 Email Sample 1: Banking Fraud (Bradesco Livelo)	
4.2 Email Sample 2: Loan Scam (Account Takeover)	
4.3 Email Sample 3: Health Scam (Brand Impersonation)	
5. Phishing Prevention Guidelines.....	12
5.1 The "Do's": Best Practices for Users	
5.2 The "Don'ts": Critical Security Mistakes	
6. Conclusion.....	12
6.1 Why Phishing Awareness Matters	
6.2 The Importance of Employee Training	

Introduction

Phishing is a type of cyber attack that uses social engineering techniques to trick individuals into revealing sensitive information such as usernames, passwords, banking details, or one-time passwords (OTPs). In a typical phishing attack, the attacker sends a fraudulent email that appears to come from a trusted organization, such as a bank, online service, or company IT department. These emails often contain malicious links or attachments designed to steal information or install malware on the victim's device.

Phishing attacks are considered one of the most dangerous and common threats in cybersecurity today. Attackers exploit human trust and curiosity rather than technical system vulnerabilities. A single successful phishing email can lead to serious consequences such as unauthorized access to company systems, financial loss, data breaches, identity theft, and the spread of malware within an organization's network. Because phishing emails are designed to look legitimate, many users may unknowingly interact with them.

Employee awareness plays a critical role in preventing phishing attacks. Even organizations with strong technical security measures can be compromised if users are unable to recognize suspicious emails. Training employees to identify common phishing indicators—such as suspicious sender addresses, urgent language, unknown links, and unexpected attachments—helps reduce the risk of successful attacks. By increasing awareness and promoting safe email practices, organizations can significantly strengthen their overall cybersecurity posture and protect both sensitive data and internal systems.

Tools Used

To analyze phishing emails and identify potential security threats, several online tools and resources were used during this project. These tools helped in examining email headers, inspecting suspicious URLs, and collecting phishing email samples for analysis. Each tool played an important role in identifying phishing indicators and understanding how phishing attacks operate.

1. **Google Admin Toolbox Messageheader** – Email Header Analysis

Google Admin Toolbox Messageheader is an online tool used to analyze email headers and trace the path an email takes from the sender to the recipient. By pasting the email header into the tool, it helps identify important information such as the originating IP address, sending mail servers, authentication results (SPF, DKIM, DMARC), and possible anomalies in the email routing process. In this project, the tool was used to detect suspicious sender information and identify whether the email originated from legitimate mail servers or potentially malicious sources.

2. **MXToolbox** – Email Header Inspection and Domain Verification

MXToolbox is a widely used online diagnostic platform that provides multiple tools for analyzing email security and domain configuration. The Email Header Analyzer feature allows users to examine email headers to verify sender authenticity, identify spoofed domains, and trace message routes. It also helps detect potential issues with domain authentication records such as SPF and DKIM. In this project, MXToolbox was used to further validate the findings from header analysis and confirm whether the sender domain appeared legitimate or suspicious.

3. Browser Developer Tools – URL and Link Inspection

Modern web browsers provide built-in developer tools that help analyze website links and domain information. These tools were used to safely inspect suspicious URLs found inside phishing emails without directly interacting with malicious content. By hovering over links and checking the destination URL, it becomes possible to identify misleading links that attempt to impersonate legitimate websites. This method helps determine whether a link redirects to a malicious domain or phishing website designed to steal user credentials.

4. Public Phishing Email Samples and Datasets from GitHub

Several publicly available repositories on GitHub were used as reference sources for phishing email samples and datasets. These repositories contain real-world examples of phishing emails, including their headers, body text, and malicious links. Studying these examples helps security analysts understand common phishing techniques such as spoofed domains, urgent language, fake login pages, and malicious attachments. These datasets were used only for educational analysis to identify common phishing indicators and improve the accuracy of the phishing detection report.

Reference link : https://github.com/rf-peixoto/phishing_pot?utm_source=chatgpt.com

5. Documentation Tools – Google Docs / Microsoft Word / PDF

Documentation tools were used to prepare a professional phishing analysis report. These tools helped organize the findings, document phishing indicators, classify email risk levels, and provide prevention guidelines in a structured and easy-to-understand format. The final report was exported as a PDF document to ensure it can be easily shared and reviewed. Proper documentation is important because it allows organizations to use the report as part of their employee awareness and cybersecurity training programs.

Phishing Email Sample Analysis

Email Sample 1 :

- Subject: CLIENTE PRIME - BRADESCO LIVELO: Seu cartão tem 92.990 pontos LIVELO expirando hoje!
- Sender: BANCO DO BRADESCO LIVELO <banco.bradesco@atendimento.com.br>
- Target: phishing@pot (Honeypot address)

Phishing Indicators Identified

- Urgent & Threatening Language: The subject line uses "expirando hoje!" (expiring today!) to create a false sense of urgency, a classic social engineering tactic to make the victim act without thinking.
- Suspicious Sender Domain: While the display name claims to be "Banco do Bradesco," the actual email domain is @atendimento.com.br. Legitimate banks typically send official communications from their primary corporate domain (e.g., @bradesco.com.br).
- Mismatched "Friendly" Name: The sender name is written in all caps, which is common in low-effort phishing attempts to grab attention.
- Authentication Failures: Technical analysis shows the email lacks a DKIM signature and failed SPF/DMARC checks, proving the sender's identity cannot be verified.

Risk Classification : ● **High Risk.**

Explanation :

This attack is a "Reward/Point Expiry" scam. The attacker impersonates a well-known Brazilian bank (Bradesco) and its loyalty program (Livelo). By telling the user they have nearly 93,000 points about to expire, they lure the victim into clicking a malicious link to "save" their points.

Once the user clicks the link (which leads to suspicious domains like the one found in the GoDaddy search: blog1seguimentmydomaine2bra.me), they are likely directed to a fake login page designed to steal their banking credentials or credit card information.

Email Header Analysis :

In this section, we analyze the technical "passport" of the email to verify if the sender is truly who they claim to be. Based on the analysis from Google Admin Toolbox and MXToolbox, the following discrepancies were found:

Feature	Result	Finding
Sender IP	137.184.34.4	Traced to DigitalOcean (Cloud Infrastructure), not a Bradesco banking server.
SPF (Sender Policy Framework)	Temperror / Fail	The sending IP is not authorized to send mail on behalf of the domain.

DKIM (DomainKeys Identified Mail)	None / Fail	The email has no digital signature, meaning the content could have been altered in transit.
DMARC Compliance	Fail	No DMARC record found; the domain lacks a policy to handle spoofed emails.

Detailed Findings :

- **Authentication Failures:** The most significant red flag is the "Temperror" and "None" status for SPF and DKIM. Legitimate financial institutions always use these protocols to protect their customers. The failure here proves that the email is unauthorized and spoofed.
- **Domain Mismatch:** While the "From" field shows `banco.bradesco@atendimento.com.br`, the Return-Path (the actual source address) is listed as `root@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06`. This shows the email was sent from a generic Linux server (Ubuntu) rather than a professional mail server.
- **Infrastructure Analysis:** The message ID `20230919183549...sfo3-06` further confirms the use of a cloud-hosted virtual private server (VPS). Attackers use these to send bulk emails quickly before the IP gets blacklisted.
- **Relay Delay:** The analysis shows a delivery delay of 56–57 seconds. While small, the relay path through various Outlook protection servers indicates the email was flagged as suspicious during transit.

Technical Conclusion :

The combination of missing DKIM signatures, unauthorized SPF, and a source IP belonging to a cloud provider rather than a banking network confirms that this is a malicious spoofing attempt.

Email Sample 2 :

- Subject: Hi
- Sender: shore@suksapan.or.th
- Reply-To: globalmeritexperts@gmail.com
- Target: Recipients <shore@suksapan.or.th> (indicating a BCC or mass-blast attempt)

Phishing Indicators Identified :

- Low-Effort Subject Line: A simple "Hi" is often used by scammers to bypass automated spam filters that look for "Loan," "Bank," or "Urgent" keywords.
- Mismatched "Reply-To" Address: While the email comes from a Thai educational/organizational domain (suksapan.or.th), the "Reply-To" address is a generic Gmail account (globalmeritexperts@gmail.com). Professional loan companies never use free Gmail accounts for business.
- Financial Bait: The email offers various loans (personal, mortgage, business) with no prior contact, a common "Advance Fee" or "Identity Theft" scam tactic.
- Poor Personalization: The email address itself is the recipient name ("Recipients <shore@suksapan.or.th>"), showing it was sent as a bulk blast rather than a targeted communication.

Risk Classification : ● High Risk Financial Fraud / compromised Account.

Explanation :

This is a "Loan Phishing" scam. The attacker likely compromised a legitimate email account (shore@suksapan.or.th) and is using its established reputation to send spam. The goal is to get the victim to email the Gmail address, where the attacker will eventually ask for "processing fees" or sensitive personal data (KYC documents) to "approve" a non-existent loan.

URL & Link Analysis :

While this email doesn't contain a traditional website hyperlink, it uses a "Mailto" URL to redirect the conversation away from the monitored corporate domain.

- Identified URL: <mailto:globalmeritexperts@gmail.com>
- Attack Vector: Off-Platform Pivot. By moving the victim to a private Gmail account, the attacker ensures their conversation isn't blocked when the original compromised account (shore@suksapan.or.th) is eventually shut down by IT administrators.
- Malicious Intent: Highly Likely. This is used to solicit "Advance Fees" for fake loans or to gather KYC (Know Your Customer) documents for identity theft.

Detailed Findings :

- The "Originating" Red Flag: Looking at the Received headers, the mail started at 102.69.139.111. In cybersecurity, seeing an email from a Thai domain (.or.th) being sent by a user logged in from an African IP address is a major indicator of a compromised account.
- SPF Alignment Failure: The header Received-SPF: SoftFail confirms that the server used to send the email is not fully authorized by the domain's security policy.
- X-SID-Result: FAIL: This internal Microsoft header shows that the Sender ID check failed completely. The system essentially "knows" this email is likely fraudulent even if it hasn't blocked it yet.

- SCL (Spam Confidence Level) of 5: In a corporate environment, an SCL of 5 typically sends the email straight to the Junk folder because the metadata doesn't match the sender's identity.

Analysis Category	Details & Findings
SPF Status	SoftFail (Sender IP not fully authorized by domain)
DKIM Status	None (No digital signature found)
DMARC Status	None (No policy published for the domain)
SCL Score	5 (High Spam Confidence Level)
Phishing Tactics	Financial bait (Loan offer), Off-platform pivot (Gmail), Account Hijacking
Target Audience	Mass blast / BCC recipients

Technical Conclusion :

The technical evidence definitively classifies this email as Business Email Compromise (BEC) via Account Takeover (ATO).

Unlike Sample 1, which utilized a look-alike domain, Sample 2 was sent through a legitimate but hijacked account (shore@suksapan.or.th). The following factors confirm the malicious nature of the communication:

- **Geographic Anomaly:** The stark discrepancy between the sender's organizational home (Thailand) and the actual login location (Mauritius) is a hallmark of credential theft.
- **Authentication Failure:** The SPF SoftFail and X-SID-Result: FAIL indicate that the email did not originate from an authorized path, despite using a "real" email address.
- **Infrastructure Pivot:** The use of a Reply-To header directing victims to a Gmail address (globalmeritexperts@gmail.com) proves the attacker's intent to move the conversation away from the organization's monitored environment to a private, unmanaged channel.
- **Automated Flagging:** An SCL score of 5 confirms that security filters recognized the metadata as inconsistent with standard professional correspondence.

Email Sample 3 :

- Subject: Individuelle Prognose für schnellen Gewichtsverlust
- Sender: otto-newsletter@newsletter.otto.de (Impersonating OTTO, a large German e-commerce company)
- Target: phishing@pot

Phishing Indicators Identified :

- Brand Impersonation (Spoofing): The "From" address claims to be from otto.de. However, the content (weight loss gummies) is completely unrelated to the retailer's actual business, a common tactic to leverage a trusted brand's reputation.
- Unrealistic Claims: The email promises "SCHMELZEN FAT SCHNELL!" (Melt fat fast!) without diet or exercise, which is a hallmark of fraudulent health scams.
- Use of URL Shorteners: The "Call to Action" buttons link to t.co (a Twitter/X shortener). Legitimate corporate newsletters typically link directly to their own verified domains.
- Technical Mismatch: The Return-Path and Reply-To headers point to granigo.art, a domain that has no association with the German company OTTO.

Risk Classification : ● High Risk Malicious Spoofing / Health Scam.

Explanation :

This attack uses "Brand Hijacking." By making the email look like an official newsletter from a trusted company, the attacker hopes to bypass the user's natural suspicion. The goal is to drive traffic to a scam website (KetoXplode) to steal credit card information or enroll victims in recurring "subscription traps."

- The "Originating" Red Flag: Looking at the Received headers, the mail started at 102.69.139.111. In cybersecurity, seeing an email from a Thai domain (.or.th) being sent by a user logged in from an African IP address is a major indicator of a compromised account.
- SPF Alignment Failure: The header Received-SPF: SoftFail confirms that the server used to send the email is not fully authorized by the domain's security policy.
- X-SID-Result: FAIL: This internal Microsoft header shows that the Sender ID check failed completely. The system essentially "knows" this email is likely fraudulent even if it hasn't blocked it yet.

Email Header Analysis :

Technical analysis confirms this is a direct spoofing attack where the attacker successfully faked the "From" address but failed the underlying security checks.

Metric	Value / Result	Interpretation
Sender IP	80.96.157.211	Traced to a server in Romania (Host: xple.granigo.art).

SPF Status	None / Fail	The domain granigo.art does not authorize the sending server.
DKIM Status	None	No digital signature; confirms the email is a forgery.
DMARC Status	Fail	Failed the otto.de DMARC policy because the "From" domain doesn't match the source.
SCL Score	9	Critical Spam Level; the highest possible "spammy" rating by Microsoft.

Detailed Findings :

- **DMARC Failure:** The email claims to be from newsletter.otto.de. While the real OTTO domain has a DMARC record, this email failed because the "Envelope From" (granigo.art) does not align with the "Header From" (otto.de).
- **Spam Confidence Level (SCL 9):** An SCL of 9 indicates that the email contains nearly every hallmark of a mass-produced phishing campaign. It would be automatically blocked or moved to the "Junk" folder in any professional environment.
- **The "Granigo.art" Connection:** Your WHOIS search (Screenshot 6.16.53) shows that granigo.art is essentially an empty or unregistered shell domain used solely as a "relay" for this attack.
- **Redirect Analysis:** The use of firiri.shop for the "Unsubscribe" link is a trick. Clicking "unsubscribe" on a scam email often just confirms to the attacker that your email address is active, leading to more spam.

URL Analysis (Malicious Links) :

- **Link 1:** <https://t.co/eYVtqVunRC> (Redirects to the KetoXplode scam site).
- **Link 2:** <http://bsq2.firiri.shop/...> (Tracking link used to monitor if the victim opened the email).
- **Analysis:** Both domains are unrelated to the sender. firiri.shop is a high-risk domain often used in bulk spam campaigns.

Technical Conclusion :

The technical evidence confirms that this email is a high-volume Brand Impersonation attack, leveraging the reputation of a major retailer (OTTO) to bypass human skepticism. However, from a technical standpoint, the attack failed almost every modern security check.

- **DMARC Alignment Failure :** Although the attacker used a legitimate-looking "From" address (newsletter.otto.de), the email failed DMARC validation. This is because the "Envelope From" (the actual return address) was granigo.art. In a secure mail system, the header domain and the envelope domain must match (alignment); since they did not, the email was flagged as a forgery.

- **Infrastructure Mismatch** : The source IP 80.96.157.211 is located in Romania and belongs to a generic hosting provider, which has no technical relationship with the German-based infrastructure of the impersonated brand.
- **Critical Spam Rating** : The SCL (Spam Confidence Level) of 9 is the highest possible score, indicating that Microsoft's security filters identified the content as "High Confidence Spam." This is likely due to the combination of health-related "spammy" keywords (e.g., "Gewichtsverlust") and the lack of a DKIM digital signature.
- **Malicious Redirection** : The use of t.co (Twitter's link shortener) is a deliberate attempt to hide the final destination of the URL. By using a reputable redirector, attackers try to trick automated URL scanners into thinking the link is safe.

Phishing Prevention Guidelines :

Based on the analysis of the previous three samples, it is clear that phishing attacks are becoming more technically diverse. To protect personal and organizational data, the following guidelines must be followed:

The "Do's": Best Practices for Email Security :

- **Verify the Sender's True Address:** Always look past the "Display Name." As seen in Sample 1, a name can say "Bank," but the email address may be entirely different.
- **Hover Before You Click:** Before clicking any link, hover your mouse over it. A small box will appear showing the actual URL. If the URL looks suspicious (like granigo.art or t.co shorteners), do not click.
- **Report to IT/SOC Team:** If you receive a suspicious email, use the "Report Phishing" button or forward it to your organization's security team. This helps them block the sender for everyone else.
- **Check for SPF/DKIM/DMARC:** If you are in a technical role, use tools like Google Admin Toolbox or MXToolbox to check if the email's technical "passport" is valid.
- **Enable Multi-Factor Authentication (MFA):** Even if an attacker steals your password (as attempted in Sample 2), MFA provides a second layer of defense that is much harder to bypass.

The "Don'ts": Common Mistakes to Avoid :

- **Do Not React to "Urgency":** Scammers use phrases like "Expiring Today" or "Account Locked" to make you panic. Take a breath and verify the claim through an official app or website instead of the email.
- **Do Not Use "Unsubscribe" Links in Spam:** In scam emails (like Sample 3), clicking "unsubscribe" often confirms your email is active, which leads to even more attacks. Just delete and block.
- **Do Not Share OTPs or Passwords:** No legitimate bank or loan company will ever ask for your password or One-Time Password (OTP) via email or phone.
- **Do Not Download Unsolicited Attachments:** Files ending in .zip, .exe, or even .pdf can contain malware or keyloggers that record your typing.

Conclusion :

Why Phishing Awareness Matters?

Phishing remains the #1 entry point for cyberattacks worldwide. As demonstrated in this report, attackers no longer rely on simple "bad grammar." They now use sophisticated methods such as:

1. **Cloud Infrastructure:** Using reputable VPS services (DigitalOcean) to hide.
2. **Account Takeovers:** Hijacking real accounts to exploit existing trust.
3. **Brand Hijacking:** Impersonating well-known companies to bypass human filters.

The technical analysis performed using Google Admin Toolbox and MXToolbox proved that while an email might look perfect on the surface, its headers rarely lie. Technical failures like SPF SoftFails, Missing DKIM signatures, and DMARC mismatches are the digital fingerprints of a scam.

The Importance of Employee Training :

Technology alone cannot block 100% of attacks. The "human element" is often the weakest link in the security chain. Regular employee training and awareness programs are critical because:

- It Builds a "Human Firewall": Trained employees are the first line of defense against social engineering.
- It Reduces Response Time: An employee who knows how to report a suspicious email can stop a breach before it spreads.
- It Promotes a Security Culture: When every team member understands the risks of "Account Takeovers" or "Malicious Redirects," the entire organization becomes a harder target for cybercriminals.

Through this internship task, we have successfully identified, analyzed, and documented real-world threats, providing a roadmap for better organizational resilience.